Table 33. Security threats specific to AI systems and planned controls

Threat (OWASP LLM Top 10, 2025)	Example in BAPIL context	Planned controls
LLM01 Prompt injection	Instructions hidden inside an ingested PDF	Treat retrieved text as data only; no tool execution; citation-only answering; red-team tests at every G2
LLM02 Sensitive information disclosure	Personal data surfacing in answers	P0-first corpus; PII scanning at ingestion; access control per collection; log redaction
LLM03 Supply chain	Compromised model weights or packages	Pinned dependencies; software bill of materials; model checksums and provenance; signed releases
LLM04 Data and model poisoning	Manipulated documents entering the corpus	Source allow-list; provenance hashes; change detection; human curation of any fine-tuning data
LLM05 Improper output handling	Model output rendered as active content	Escape all output; structured-output validation; no direct execution
LLM06 Excessive agency	Tool given authority to act on systems	Read-only design; no autonomous actions; human approval for any change
LLM07 System prompt leakage	Secrets placed in prompts	No secrets in prompts; prompts versioned and published where possible
LLM08 Vector and embedding weaknesses	Cross-collection leakage in the index	Per-collection access control enforced at query time; tenant isolation
LLM09 Misinformation	Confident but wrong answer	Mandatory citations; abstention; confidence display; user training
LLM10 Unbounded consumption	Query floods driving up compute cost	Quotas, rate limits, timeouts, cost monitoring

Source: BAPIL Technical Blueprint, Version 1.0 (2026). CC BY 4.0.